

Defect 1 — Inviting unregistered emails Severity: Medium Fix: Invite by email is supposed to look up an existing user and add them directly, but it's not checking if the email exists first. It should return a 404 error if the email isn't registered. The fix would be in workspace.service.ts in the inviteByEmail function — it needs to check if the user exists before adding them, and throw an error if not.

Defect 2 — Can't remove email when making a workspace Severity: Low Fix: This is a frontend issue — the create workspace form doesn't allow clearing or editing the email field once

filled in. The fix would be adding a clear/remove button next to the email input field in the frontend form component.

Defect 3 — Can't revoke shareable invite link Severity: Medium Fix: Once a leader generates an invite token there's no way to cancel it, meaning anyone who gets that link can join forever until it expires. The fix would be adding a new endpoint like DELETE /workspaces/:id/invite that invalidates the current invite token, which would require storing the token (or a hash of it) somewhere in the database so it can be marked as revoked.

Defect 4 — Refresh token lasts too long

Severity: High Fix: The refresh token is currently set to 7 days in both .env and auth.controller.ts. This is a significant security risk as a stolen token remains valid for an extended period. The fix would be reducing JWT_REFRESH_EXPIRY and REFRESH_TOKEN_TTL to 15m (15 minutes), and ensuring revoked tokens are promptly cleaned up from the database after logout to prevent any further misuse within that window.

Defect 5 — No option to update the task Severity: High Fix: The backend has a working PATCH /workspaces/:id/tasks/:taskId endpoint but there is no UI in the frontend to trigger it. Users have no way to edit a task once created. The fix would be adding an edit button on the task

page in the frontend that opens a form pre-filled with the current task details and calls the existing PATCH endpoint.